Week 02 — Assets, Threats and Risk

> What matters? What can harm it? How serious is it? Slides: week02-assets-threats-and-risk.pdf

Three questions organize the lecture

1. Assets	2. Harm / controls	3. Risk
What is valuable?	*How could harm occur?*	*How likely and how serious?*
Identify four asset types, then explain their value and needs.	Learn four roles (threat, vulnerability, exploit, control), then examine protection.	Define two ratings (likelihood, impact), then combine them.

One hospital story connects the lesson: WannaCry disrupted **NHS** services in **May 2017**. (NHS = National Health Service, England's public healthcare system.)

Real cases used this week

Case	Year	What happened	Used to explain
WannaCry / NHS	May 2017	Ransomware disrupted hospital services	Malicious threat, availability, impact on care
Equifax	2017	Attackers used an unfixed software flaw to reach personal information	Vulnerability vs exploit, patching, confidentiality
GitLab	2017	Database data deleted by mistake; recovery was hard	Accidental threat, integrity, backup vs restore
Facebook	4 Oct 2021	A network setting change cut communication between data centers, so services went down	Dependency, availability
Kakao	2022	A data-center fire disrupted services	Physical threat
Uber	Sep 2022	A contractor approved a login after repeated requests	Authentication, MFA fatigue
Cloudflare	2022	Staff entered details on a fake site, but security keys blocked the login	Origin-bound security keys

---

1. Assets

Identify assets, classify them, then explain their protection needs.

Asset = something valuable to protect

> An **asset** is something valuable that needs protection.

NHS example: records, computers, staff and healthcare services all support care.

Four asset types: what are we protecting?

Assets take different forms. These four categories help us identify **what needs protection before choosing protection**.

Type	Meaning	Examples	Real case
Information	Useful facts we depend on	Patient records, grades, passwords, appointment details	**Equifax 2017** (personal data exposed)
Devices	Physical tools that support work	Laptops, phones, hospital computers	**NHS, May 2017** (computers locked by WannaCry)
People	Knowledge, work and wellbeing	People provide knowledge, skills and essential work	**NHS, May 2017** (staff and patients affected)
Services	Functions people rely on	Online exams, messaging, payments, appointments	**Facebook, 4 Oct 2021** (services unavailable)

Why an asset list is only the beginning

Once an asset is on the list, ask three more questions:

1. **Value:** *Why does the asset matter?* NHS systems support care.
2. **Dependency:** *What does it need to work?* A service needs working devices and networks.
3. **Protection goals:** *What must be preserved?* Use confidentiality, integrity and availability.

Value, dependency, and protection

Value. Imagine two similar computers: one shows a public notice, the other supports an urgent service. Their **prices may be the same**, but **interruption has different consequences**. Value comes from what the asset *does*, not what it costs.

Dependency. A dependency is **something else you need**. Facebook's October 2021 outage showed why these connections matter. Several services can rely on **the same underlying system** and so **fail together**.

Facebook: devices alone were not enough

- **Data center** = a building with computing equipment.
- **Facebook, 4 October 2021:** a network setting change interrupted communication between data centers.
- Services became unavailable, even though the computers themselves were fine.

> **Dependency: services need communication.**

Week 1 link: what can an asset lose?

Goal	Meaning	Real case
C Confidentiality	Only permitted people can access it	**Equifax:** private data was exposed
I Integrity	Information stays correct and complete	**GitLab:** database data was deleted
A Availability	It is usable when needed	**NHS:** healthcare work was disrupted

Activity: identify the assets

> Real case: WannaCry disrupted NHS healthcare in 2017. Use the four asset categories to explain what needed protection.
>
> 1. Name one information asset. 2. Name one device asset. 3. Name the people affected. 4. Name the service and its value.

Answers: connect each asset to its value

1. **Information:** patient and appointment records support decisions.
2. **Devices:** computer systems let staff use that information.
3. **People:** staff provide knowledge and care; patients are affected.
4. **Services:** healthcare must remain usable when needed.

Next: what could harm these assets?

We can name what matters (**known:** assets and their value). Next come **threats, weaknesses and exploits**, then **controls** that reduce the harm.

---

2. Harm and Protection

Explain harm, identify weaknesses, examine controls.

Four concepts explain harm and protection

These four roles explain the Equifax incident step by step:

Term	Meaning
Threat	A possible cause of harm
Vulnerability	A weakness
Exploit	A way to use a weakness
Control	A protective measure

Threat = a possible cause of harm

> A **threat** is something that could cause harm to an asset. Threats may be **deliberate, accidental or physical**.

M: Malicious	A: Accidental	P: Physical
Deliberate harm	Unintended harm	Physical damage
WannaCry, 2017: harmful software disrupted services	**GitLab, 2017:** database data was deleted by mistake	**Kakao, 2022:** a data-center fire disrupted services
Harmful software	A mistake causes harm	Buildings and power matter

A threat does **not** have to be a person with bad intentions: a mistake or a fire is also a threat.

WannaCry: malware and ransomware

- **Malware** = software designed to cause harm.
- **Ransomware** = malware that **blocks access and demands payment**.
- WannaCry disrupted NHS work in May 2017, mainly an **availability** attack on an essential service.

Vulnerability = a weakness that permits harm

> A **vulnerability** is a weakness that could allow harm.

Equifax, 2017: an **unfixed software flaw** allowed attackers to gain access.

Threat and vulnerability are different

Threat	Vulnerability
What could cause harm?	*What weakness could permit harm?*
Equifax: **attackers** sought access to personal information.	Equifax: the affected web software had **a flaw that had not been fixed**.

> **The attackers are the threat; the flaw in the software is the weakness they used.**

Exploit = take advantage of a weakness

- An **exploit** is a **method or tool that uses a vulnerability**.
- To **exploit** a flaw means to use it to cause an unintended result.
- Equifax: attackers **used** the flaw to gain access.

> **Vulnerability = the flaw. Exploit = its use.**

When possible harm becomes an incident

Incident	Possible future risk
Something **has happened** that harms or threatens security.	**Possible future** harm, judged by its chance and seriousness.
WannaCry disrupted NHS services in 2017.	A similar exposed system might suffer disruption.

Control = a measure that reduces harm

- A **control** is protection that **lowers the chance or seriousness** of harm.
- A **software fix** can remove a known weakness.
- The control makes exploitation **through that weakness** less likely.

Controls can prevent, detect or recover

1. **PREVENT**	2. **DETECT**	3. **RECOVER**
Stop harm before it occurs	Notice a problem	Restore useful work
Example: fix a known software flaw	*Example:* check records of unusual access	*Example:* recover data from a tested copy

Patch = an update that fixes a problem

Patch and patching	Equifax lesson
A **patch** is a software update that fixes a problem. **Patching** means applying the update.	**A patch instruction was not enough.** The affected system needed the fix, **and completion needed checking**.

Knowing a patch exists doesn't protect you. The patch has to be **applied and verified** on the actual system.

Why account access needs its own controls

Patching protects software. **Accounts** also need protection. Four terms explain the Uber and Cloudflare cases:

Term	Meaning
Phishing	A deceptive message or website tries to trick someone. It may ask for a password or a login approval.
Credentials	Evidence used to prove identity, such as login details. (Cloudflare's 2022 attackers tried to steal staff credentials.)
Authentication	The process of checking a claimed identity.
MFA	Multi-factor authentication: more than one **kind** of identity evidence.

MFA example: password = **what you know**; security key = **a device you have**.

Uber: an unwanted login was approved

- **Contractor** = an outside worker. **Compromised** = accessed without permission.
- **Uber, September 2022:** after **repeated requests**, a contractor **approved a login**, and an attacker gained account access.

> **Lesson:** check unexpected login requests. If you didn't start the login, don't approve it.

Cloudflare: a key checked the real website

- **Security key** = a physical login device.
- **Cloudflare, 2022:** staff **submitted login details** on a fake site, **but the keys blocked the fake-site login**.
- **Origin-bound** = works only where it belongs. The key checks *which website* is asking, so it refuses to work for a fake site.

Compare what the control actually requires

Cloudflare 2022	Uber 2022
The **security key checked the website's identity**.	After repeated requests, **a person approved** a login.
Stolen login details were **insufficient** for that route.	The attacker **gained access** to an account.

Takeaway: a control that depends on a person's judgment under pressure (tapping "approve") is weaker than one that **checks automatically** (an origin-bound key).

Why recovery follows prevention

Prevention can fail. Recovery limits the harm. GitLab's deletion raises a new question: *can useful data be recovered?* That needs two terms.

Backup and restore are different actions

Backup	Restore
Make a separate copy for recovery.	**Use** a copy to recover usable data or service.
A completed copy is **only the beginning** of a recovery plan.	GitLab's 2017 incident showed why **recovery must be tested**.

A backup you have never restored from is an assumption, not a guarantee.

Practice: label the Equifax incident

> Equifax, 2017: attackers used an unfixed software flaw to gain access to personal information.

Answers: each term has a different job

1. **Asset:** personal information that needed protection.
2. **Threat source:** attackers seeking access.
3. **Vulnerability:** the unfixed software flaw. **Exploit:** using it.
4. **Control:** a **verified** patch addresses that flaw.

---

3. Assessing Risk

Judge possible harm: how likely and how serious?

Three tools for a simple risk assessment

Tool	Meaning	Ask
1. Likelihood	The chance of a harmful event	*How likely is it?*
2. Impact	The seriousness of the consequences	*How much harm?*
3. Risk matrix	A grid that combines both ratings	Use it to compare the attention needed

> **Risk** = possible harm judged by **likelihood** and **impact**.

Define the event before rating it

1. **Event:** *What harmful event do we mean?* e.g. an attacker gains account access.
2. **Period:** *Over what period?* e.g. before next month's exam.
3. **Current controls:** *What protection is working now?* e.g. Cloudflare's keys blocked one login route.

You can't rate "hackers" in general. You rate a **specific event, over a specific period, given current controls**.

Separate facts, assumptions and unknowns

F: Fact	A: Assumption	?: Unknown
Supported by evidence	Accepted for this exercise	Missing evidence
Equifax's affected software flaw was not fixed.	A similar system has a reachable weakness.	Has the relevant fix been applied and checked?

Likelihood: three labels

1. Unlikely	2. Possible	3. Likely
Not expected under the stated conditions and controls	Could happen; a believable route to harm exists	Expected, or strongly supported by evidence

Impact: three labels

1. Minor	2. Serious	3. Severe
Small disruption; routine recovery; little lasting harm	Important work or privacy is affected; extra help or time is needed	Essential service loss, or major harm that is difficult to reverse

Real incidents show different kinds of impact

C: Care	P: Privacy	W: Work
NHS, 2017: healthcare disruption affected appointments and care	**Equifax, 2017:** personal information was exposed	**GitLab, 2017:** lost database changes affected users' work
Can care continue?	*Who can see private data?*	*What work must be redone?*

Risk matrix: combine two ratings

Score = Likelihood × Impact

Likelihood ↓ / Impact →	1 Minor	2 Serious	3 Severe
3 Likely	3 Medium	6 High	9 High
2 Possible	2 Low	4 Medium	6 High
1 Unlikely	1 Low	2 Low	3 Medium

Bands: **1–2 = Low**, **3–4 = Medium**, **6–9 = High**.

Worked risk example: hospital disruption

1. **Likelihood: 3.** Assume an active threat can reach a system missing the relevant fix.
2. **Impact: 3.** Assume an essential care service would stop and recovery would be slow.
3. **Score: 3 × 3 = 9, High.**

Assumed ratings: likelihood (L), impact (I)

#	Scenario	L	I	Score	Level	Why
1	WannaCry-like disruption: essential care stops	3	3	9	**High**	Active threat plus essential service
2	GitLab-like deletion: a recent restore works	2	1	2	**Low**	A working restore keeps the impact minor
3	Cloudflare-like route: strong key protection	1	3	3	**Medium**	The key makes success unlikely, but success would still be severe
4	Update failure: essential work is interrupted	2	3	6	**High**	Possible, and severe if it happens

(The slide gives the L and I values; the scores and levels come from the matrix.)

A patch can reduce likelihood

Before the control	After verification
Equifax. A reachable unfixed flaw creates an attack opportunity.	The relevant patch is **applied and checked**.
	That exploitation route is reduced; **other weaknesses may remain**.

Patch → lowers likelihood.

A usable restore can reduce impact

Without usable recovery	With tested recovery
GitLab's 2017 incident: lost recent data can **remain lost**.	Classroom example: a recent protected copy **restores successfully**.
Recovery gaps can increase harm.	Less work may be lost, but **some harm can remain**.

Tested restore → lowers impact.

Review: six terms you should be able to explain

Term	Meaning
Asset	Something valuable
Threat	Possible cause of harm
Vulnerability	A weakness
Exploit	A way to use a flaw
Control	A protective measure
Risk	Possible harm judged by likelihood and impact

Practice: explain before you calculate

1. Why are a computer and its stored records different assets? A computer is a **device**; its records are **information**.

2. In Equifax, what was the vulnerability and what was exploitation? The **flaw** was the vulnerability; **using it** was exploitation.

3. Does a tested restore mainly reduce likelihood or impact? Impact. A usable restore means less harm after a loss.

4. What does likelihood 2 × impact 3 mean in our matrix? 2 × 3 = **6, High**: a possible event with severe consequences.

Assignment: assess an online exam

> Fictional exercise, exam in 30 days. A public exam system has an **unfixed software flaw**. A **backup exists**, but **nobody has tested restoring it**.
>
> 1. Name the four asset types. 2. Explain a possible harmful event. 3. Rate likelihood and impact. 4. Choose and explain a control.

Report your reasoning in **four sentences**, using the terms and then explaining them in plain English:

1. "The asset is …; it matters because …"
2. "The threat could use …, which is the weakness."
3. "Likelihood is … and impact is … because …"
4. "Our control is …; it reduces …"

How to reason about it:

- **Assets:** information (exam questions, answers, student data), devices (the exam servers), people (students, staff), service (the online exam itself).
- **Event:** an attacker exploits the unfixed flaw, and the untested backup fails to restore.
- **Rating:** the flaw is public and unfixed, so likelihood is **Likely (3)**. Losing the exam service and data is **Severe (3)**. **3 × 3 = 9, High.**

- **Controls: patch and verify** the flaw (reduces likelihood) and **test the restore** (reduces impact).

My submission: assignment/submission.pdf.

Reading: Chuck Easttom, *Computer Security Fundamentals* (5th ed.); Stallings & Brown, *Computer Security: Principles and Practice* (5th ed.).

Most important for exams

- **Four asset types: information, devices, people, services**. Give an example and a real case for each.
- An asset list is only the start: ask about **value**, **dependency** and **protection goals (CIA)**. Same price ≠ same value. Shared dependencies can **fail together** (Facebook 2021).
- **Threat ≠ vulnerability ≠ exploit.** Threat = *who/what* could cause harm (the attackers); vulnerability = the *weakness* (the unfixed flaw); exploit = *using* the weakness. The Equifax labelling is a classic exam question.
- **Threat types:** malicious (WannaCry), accidental (GitLab), physical (Kakao fire).
- **Incident** = has happened; **risk** = possible future harm.
- **Controls: prevent, detect, recover.** A patch must be **applied and verified** (Equifax).
- **MFA** = more than one *kind* of evidence (know / have). **Uber:** a person approved a login after repeated prompts. **Cloudflare:** an **origin-bound** security key blocked the fake site.
- **Backup ≠ restore.** A backup must be **tested** (GitLab).
- **Risk = likelihood × impact**, each rated 1–3. Know the matrix: **1–2 Low, 3–4 Medium, 6–9 High**. Define the **event, period and current controls** first, and separate **facts, assumptions and unknowns**.
- **A patch lowers likelihood; a tested restore lowers impact.**